

What Is Offensive Security?

Unit 01 — Ethics, Law & the Hacker Mindset

Before we touch a single tool, we learn the one rule everything else depends on:
authorization is the only line between a penetration tester and a criminal.

Learning objectives

By the end of this unit you can:

- **Define** offensive security and explain why companies pay people to attack their own systems.
- **Distinguish** white-, gray-, and black-hat hackers, and red vs. blue teams.
- **Explain** in plain language what the CFAA prohibits — and that minors are not exempt.
- **Identify** authorization and scope as the dividing line between a tester and a criminal.

Learning objectives (cont.)

- **Explain** responsible disclosure and how bug-bounty programs work.
- **Classify** real scenarios as legal/illegal and ethical/unethical — and justify each.
- **Apply** effective learning strategies and the "Try Harder" mindset.
- **Set up** the lab journal you will keep all semester.



The one rule

**Authorization is the only line
between a penetration tester
and a criminal.**

Everything offensive in this course happens **only** in isolated, pre-approved labs — and **only** after the AUP is signed.

Day 1 — What is offensive security, and why does it exist?

Warm-up

On the board:

*"Why would a company **pay** someone to break into its own systems?"*

Write a one-sentence guess. We'll share a few.

Offensive security, defined

- **Offensive security** = attacking systems *on purpose, with permission*, to find weaknesses before criminals do.
- A **penetration test (pentest)** is an authorized, simulated attack that finds and **reports** weaknesses.
- A **penetration tester** is hired, given **written permission**, attacks, and writes a report.

The deliverable is a report that makes the defenders stronger — not damage.

The core idea

You can't protect what you don't understand.

- Defenders need to know how attackers actually think.
- Finding the weak door first means you can lock it before a criminal walks through.
- **Offense feeds defense.** That's the whole point of this field.

Real-life analogies

Real world	Security equivalent
A locksmith picks your lock to prove it's weak	A tester finds a weak login
Crash-testing a car before it ships	Testing an app before attackers do
A fire drill	A simulated attack / red-team exercise

Good-guy testers find the weakness **so it can be fixed** — with permission.

Day 1 work: start your lab journal

A **lab journal** records *what you did, what happened, and what you learned*. Pros keep one so their work is repeatable and reportable.

First entry (baseline): write 3–5 sentences answering —

"What do I think hacking is right now?"

You'll revisit this at the end of the course to see how far you came.

Day 1 exit ticket

Finish the sentence in one line:

"Offensive security exists because ____."

Day 2 — Hats, teams, and the hacker mindset

The hacker "hats"

Hat	What they do	Legal?
White hat	Works with permission , reports problems to be fixed	 Legal
Gray hat	Acts without permission , claims good intentions	 Still illegal
Black hat	Attacks without permission for harm, theft, or gain	 Illegal

Gray hat is NOT a safe middle ground

- "I meant well" does **not** create authorization.
- A gray hat still accessed a system **without permission** — that's the crime.
- Good intentions don't change the law, and they won't protect you.

If you don't have permission, the color of your "hat" doesn't matter.

Red team vs. blue team

Team	Role
Red team	The "attackers" — simulate real adversaries
Blue team	The "defenders" — detect, respond, and stop attacks
Purple team	Red + blue working together to improve both

Both sides are on the **same side**: making the organization safer.

The hacker mindset

- Deep **curiosity** about how things work.
- A drive to find clever, **unexpected** uses for things.
- Thinking about how a system could be **misused** — then defending it.

This is a **defensive superpower** — when it's channeled ethically and with permission.

Same skill, different choice

Skill: finding a hidden web page	Ethical use	Illegal use
Where?	An authorized lab / bug-bounty target	A site you don't own
Permission?	Yes, in writing	None
Result?	A report that gets it fixed	A crime

The **skill** is identical. The **choice** is everything.

Day 2 exit ticket

"Why is 'gray hat' still risky and usually illegal?"

Journal prompt: describe a time your curiosity helped you figure something out — and how that same curiosity could be channeled in security.

Day 3 — The law: CFAA, scope & authorization

Rapid true/false warm-up

- "Scanning a website you don't own is fine if you don't change anything." → **False**
- "Owning hacking tools is illegal." → **False**
- "Minors can't get in trouble for hacking." → **False**

The CFAA

The **Computer Fraud and Abuse Act** (18 U.S.C. § 1030) is the main U.S. federal anti-hacking law.

It prohibits:

- Accessing a computer "**without authorization**"
- "**Exceeding authorized access**" (you were allowed in *here*, but went *there*)

State computer-crime laws add even more.

Minors are NOT exempt

- Being a student does **not** make unauthorized access legal.
- Consequences can include juvenile or criminal charges, school discipline, and lasting records.
- The goal here isn't fear — it's **informed, ethical decision-making.**

"Just looking" can still be illegal

- Even **scanning** or "just looking around" can break the CFAA and the school AUP.
- "I didn't change anything" is **not** a legal defense.
- The harm is the **unauthorized access itself**, not just damage.

Tools are dual-use

- The **same tools** are used by professionals and by criminals.
- Owning a security tool is generally **legal**.
- **Using it without permission** is not.

A tool can't make an action legal or illegal — **authorization** does.

Authorization + scope = the line

Term	Meaning
Authorization	Explicit, written permission from the owner to test a specific system
Scope	The exact list of systems, addresses, and actions you may test — and nothing else

The same scan is a **job** with authorization, and a **crime** without it.

Day 3 exit ticket

"In your own words: what is the difference between a pentester and a criminal?"

Then begin **Part 1 of the Scenario Worksheet** (legal vs. illegal classification, scenarios S1–S4).

Day 4 — Responsible disclosure, bug bounties & real cases

The grading-portal problem

A student finds the school grading portal shows **other students' grades** if you change a number in the web address.

What is the **right** thing to do?

What could go wrong if they "just look around to be sure"?

Responsible disclosure

If you discover a real vulnerability — even by accident:

-  Do **not** exploit it further.
-  Do **not** share it publicly or with friends.
-  **Report it privately** to the owner or a trusted adult.
-  Give them time to fix it.

Discover by accident → stop → report. Don't poke at it to "be sure."

Bug-bounty programs

- A **bug bounty** is a program where an organization **pays** ethical hackers to find and report vulnerabilities — **legally**.
- The company publishes a **scope page** = your authorization for those targets.
- This is **coordinated disclosure**: the legitimate, rewarded path.

Want to use these skills for real? Bug bounties and CTFs are the legal door.

Responsible-disclosure role-play

In pairs, practice a real report:

- **Discoverer** — found the issue by accident.
- **Owner** — the company/IT contact receiving the report.
- (**Observer** — gives feedback, if you have a third.)

The Discoverer reports it **clearly, respectfully, privately** — does **not** exploit or share. Then **swap roles**.

Day 4 exit ticket

*"Name one thing a responsible hacker does **not** do after finding a bug."*

Then finish the **Scenario Worksheet** (Part 2: ethical vs. unethical + "Would you report it?", scenarios S5–S8).

Day 5 — Learning to learn + the ethics pledge

Effective learning strategies

- **Take good notes** — your lab journal is your memory.
- **Break problems into steps**; document what you tried.
- **Ask for help the right way**: what you tried, what happened, what you expected.
- Persistence beats raw talent in this field.

The "Try Harder" mindset

- **Persistence and productive struggle** before giving up.
- Sitting with a hard problem is where the learning happens.
- **NOT** recklessness or rule-breaking.

Frustration is **never** an excuse to attack something out of scope.

Strong vs. weak journal entries

Weak entry	Strong entry
"Did the lab. It worked."	Date, exact command, the result, and what I learned
No reasoning	Notes <i>why</i> I tried something
Can't be repeated	Anyone could repeat my steps

Day 5: sign the pledge & assess

- Complete and **sign the ethics reflection** (the pledge + short written reflection).
- Submit the completed **Scenario Worksheet** (all 8).
- Take the **Unit 01 quiz**.

Ethics reflection prompt: *Why does authorization matter so much? Describe one situation where you might be tempted to cross a line, and what you'd do instead.*

Full vocabulary (1 of 2)

Term	Meaning
Offensive security	Attacking systems on purpose, with permission , to find weaknesses first
Pentest / pentester	An authorized simulated attack / the pro who performs and reports it
White hat	Ethical hacker; works with permission, reports issues
Gray hat	Acts without permission, claims good intent — still illegal
Black hat	Criminal attacker, no permission
Red / Blue team	Simulated attackers / defenders

Full vocabulary (2 of 2)

Term	Meaning
Hacker mindset	Curiosity + clever, unexpected uses — a defensive superpower
Authorization	Explicit written permission to test a system
Scope	The exact systems/actions you may test — and nothing else
CFAA	Main U.S. federal anti-hacking law (18 U.S.C. § 1030)
Vulnerability / Exploit	A weakness / the technique that abuses it
Responsible disclosure	Privately reporting a bug instead of exploiting/publishing
Bug bounty	Paid, legal program to find and report bugs
Scanning	Probing to learn what's running — illegal without authorization
AUP / Lab journal	Acceptable Use Policy / your running record of work

Lab: Ethics, Law & the Hacker Mindset

No tools. No hacking. No scanning. You will read, classify, discuss, and role-play. There is nothing to attack here — and that is the point.



Lab safety & authorization reminder

You may only run offensive techniques inside the approved, isolated labs your teacher provides — and only after your AUP is signed. Doing this to any system you don't own or have **written permission** to test — the school, classmates, or any website — is **illegal** under the CFAA and state law. **Minors are not exempt.**

Copy this onto **page 1** of your lab journal by hand.

Lab Part 1 — Journal setup

1. Get your lab journal (bound notebook or shared digital doc).
 2. **Cover:** your name, course, term.
 3. **Page 1:** copy the safety/authorization reminder above.
 4. Title the page "Unit 01 — Ethics & Law" and date it.
 5. Write your **baseline entry**: *"What do I think hacking is right now?"*
-  Take a photo/screenshot of page 1 for your deliverable.

Lab Part 2 — Scenario classification

For each scenario, decide **two** things and write one sentence of justification for each:

- 1. Legal or illegal?** (Is there authorization? Is it in scope?)
- 2. Ethical or unethical?** (Even if legal, was it the right thing?)

Legal and ethical aren't always the same — say so in your reasoning.

Sample scenarios

- **S1.** Maya signs a contract listing exactly which servers she may test, tests only those, reports. → *Legal / Ethical*
- **S2.** Devon changes a number in the grading-portal URL "just to confirm," tells no one. → *Illegal / Unethical*
- **S4.** Sam port-scans a popular site "to practice," no permission, changes nothing. → *Illegal / Unethical* ("just looking" is no defense)
- **S7.** Jordan completes a TryHackMe room on the class's provided AttackBox. → *Legal / Ethical*

Lab Part 3 — Disclosure role-play

In pairs, using a scenario card:

- 1. Assign roles** — Discoverer and Owner (Observer if 3).
- 2. Run the report** (5–7 min): report privately, clearly, respectfully — **don't** exploit or share.
- 3. Swap roles** and run it again.
- 4. Journal it:** What did a good disclosure sound like? What did the Discoverer avoid, and why?

Lab deliverables

-   Completed **Scenario Worksheet** (all 8, both classifications + justifications).
-   **Signed ethics reflection** (pledge + reflection).
-   **Lab journal**: page-1 safety reminder, baseline entry, role-play reflection — with a photo of page 1.

Recap

- Offensive security exists because **you can't protect what you don't understand.**
- **White / gray / black hats** — gray is still illegal. **Red** attacks, **blue** defends.
- The **CFAA** bans access "without authorization" or "exceeding authorized access" — **minors included.**
- **Authorization + scope** is the line. **Tools are dual-use.**
- Found a bug? **Don't exploit, don't share — report privately.** Bug bounties are the legal path.
- **"Try Harder"** = persistence within the rules.

Exit ticket & discussion

1. What is the **single dividing line** between a pentester and a criminal?
2. Why is "just looking" or scanning **not** a safe defense?
3. You find a real bug by accident — what are the **three** things you do (and don't do)?

Discuss: The same network scan is a paid job for one person and a crime for another. **Why?**

Submit: signed ethics reflection + completed Scenario Worksheet + lab journal page 1.